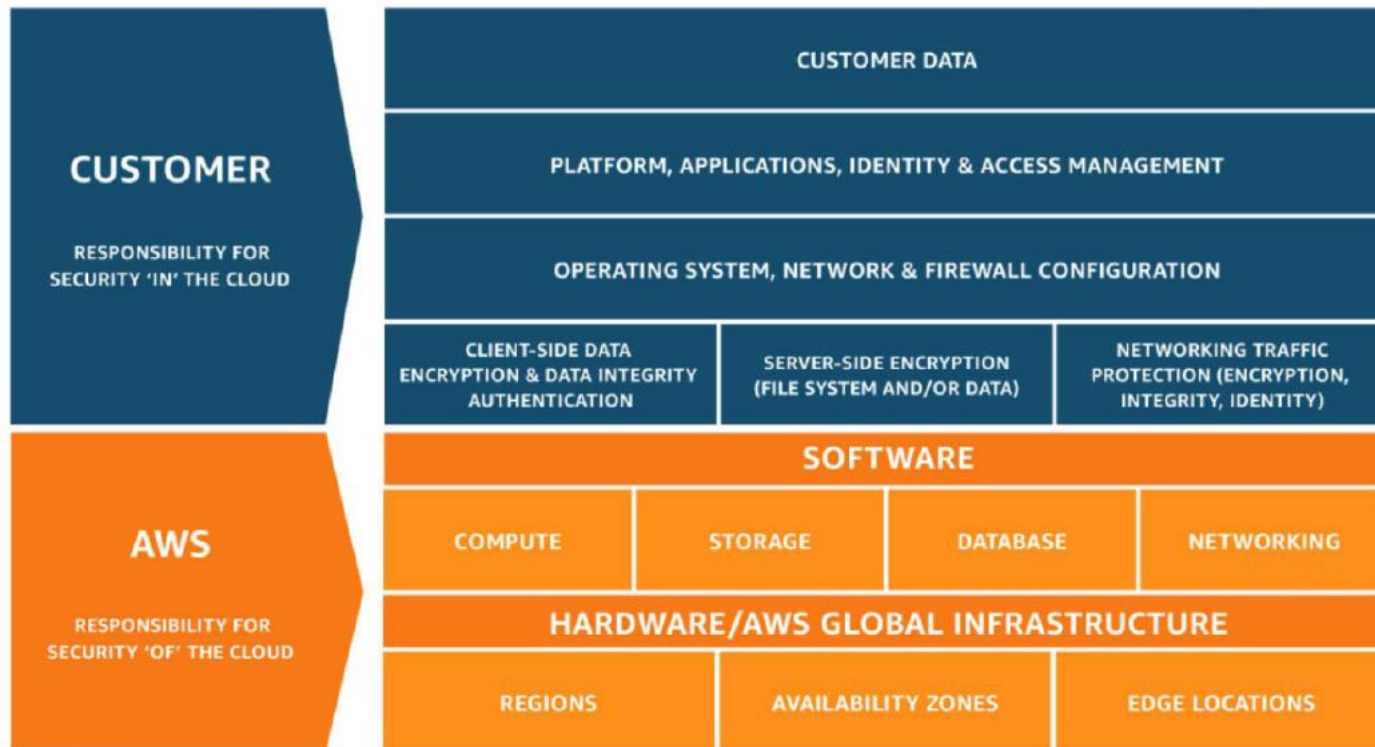


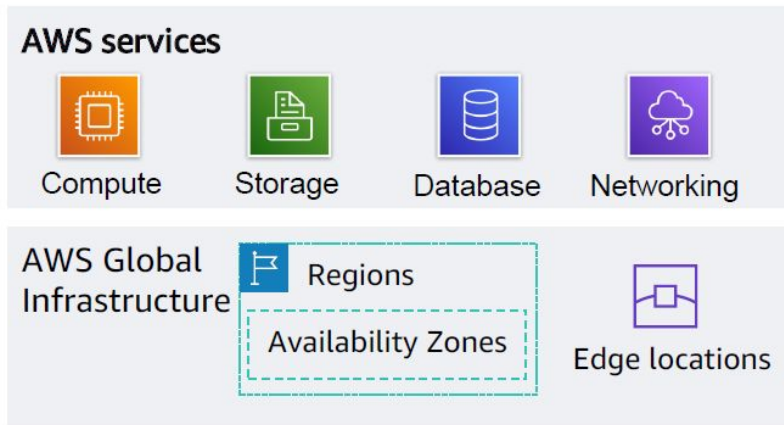
Module-6 **AWS Security and - Compliance**

AWS Security and Compliance, AWS Shared Responsibility Model, AWS Key Management Service (KMS), AWS WAF (Web Application Firewall), AWS Shield, AWS Security Best Practices

AWS shared responsibility model



AWS responsibility: Security *of* the cloud

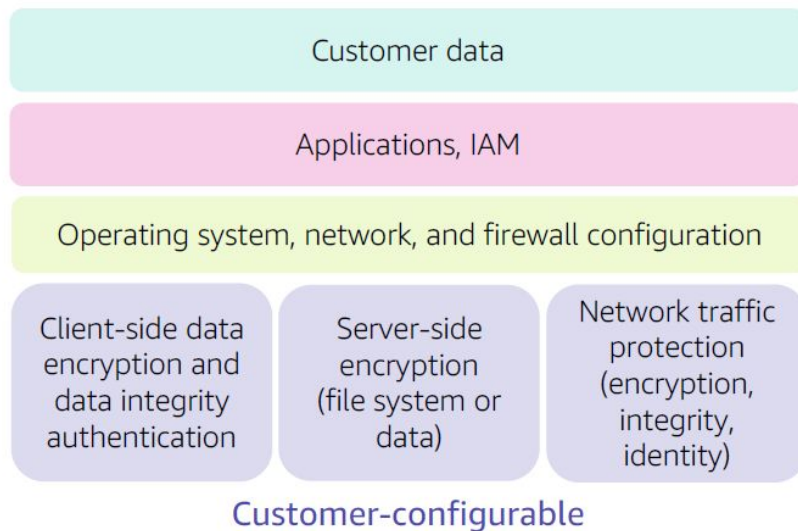


AWS responsibilities:

- Physical security of data centers
 - Controlled, need-based access
- Hardware and software infrastructure
 - Storage decommissioning, host operating system (OS) access logging, and auditing
- Network infrastructure
 - Intrusion detection
- Virtualization infrastructure
 - Instance isolation



Customer responsibility: Security *in* the cloud



Customer responsibilities:

- Amazon Elastic Compute Cloud (Amazon EC2) instance **operating system**
 - Including patching, maintenance
- **Applications**
 - Passwords, role-based access, etc.
- **Security group** configuration
- OS or host-based **firewalls**
 - Including intrusion detection or prevention systems
- **Network** configurations
- Account management
 - Login and permission settings for each user

Service characteristics and security responsibility

Example services managed by the customer



Amazon
EC2



Amazon Elastic
Block Store
(Amazon EBS)



Amazon
Virtual Private Cloud
(Amazon VPC)

Example services managed by AWS



AWS
Lambda



Amazon
Relational Database
Service (Amazon RDS)



AWS Elastic
Beanstalk

Infrastructure as a service (IaaS)

- Customer has more flexibility over configuring networking and storage settings
- Customer is responsible for managing more aspects of the security
- Customer configures the access controls

Platform as a service (PaaS)

- Customer does not need to manage the underlying infrastructure
- AWS handles the operating system, database patching, firewall configuration, and disaster recovery
- Customer can focus on managing code or data

Service characteristics and security responsibility

SaaS examples



AWS Trusted
Advisor



AWS Shield



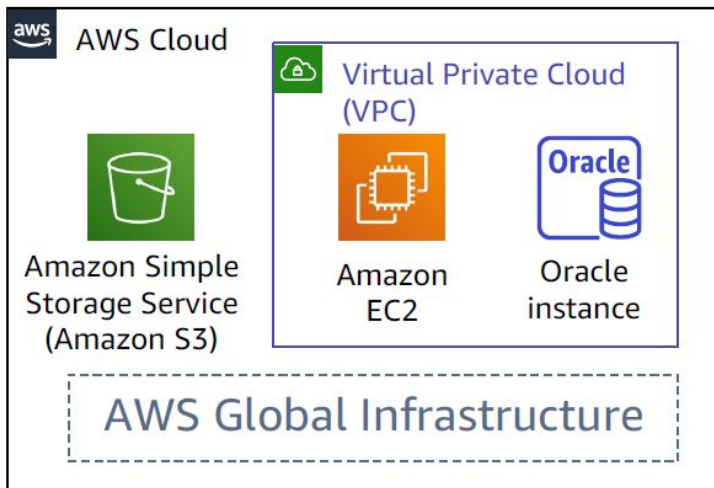
Amazon Chime

Software as a service (SaaS)

- Software is centrally hosted
- Licensed on a subscription model or pay-as-you-go basis.
- Services are typically accessed via web browser, mobile app, or application programming interface (API)
- Customers do not need to manage the infrastructure that supports the service

Activity: Scenario 1 of 2

Consider this deployment. Who is responsible – AWS or the customer?

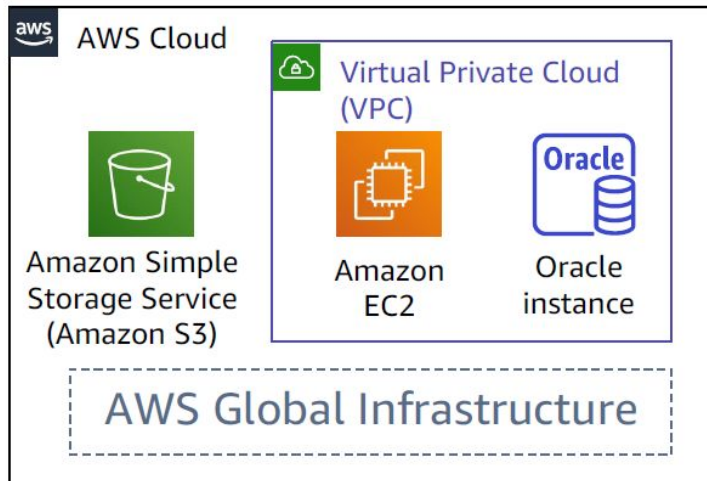


1. Upgrades and patches to the operating system on the EC2 instance?
2. Physical security of the data center?
3. Virtualization infrastructure?
4. EC2 security group settings?
5. Configuration of applications that run on the EC2 instance?
6. Oracle upgrades or patches If the Oracle instance runs as an Amazon RDS instance?
7. Oracle upgrades or patches If Oracle runs on an EC2 instance?
8. S3 bucket access configuration?

Activity: Scenario 1 of 2 Answers

Consider

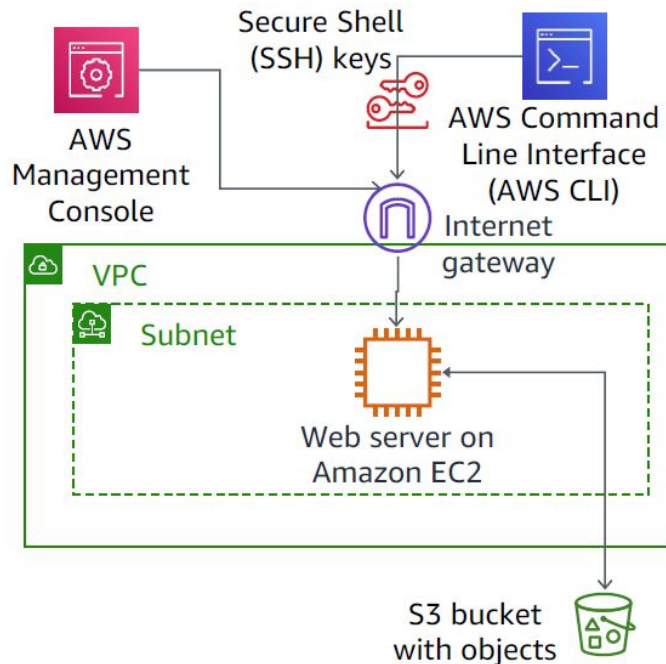
Consider this deployment. Who is responsible – AWS or the customer?



1. Upgrades and patches to the operating system on the EC2 instance?
 - **ANSWER:** The customer
2. Physical security of the data center?
 - **ANSWER:** AWS
3. Virtualization infrastructure?
 - **ANSWER:** AWS
4. EC2 security group settings?
 - **ANSWER:** The customer
5. Configuration of applications that run on the EC2 instance?
 - **ANSWER:** The customer
6. Oracle upgrades or patches If the Oracle instance runs as an Amazon RDS instance?
 - **ANSWER:** AWS
7. Oracle upgrades or patches If Oracle runs on an EC2 instance?
 - **ANSWER:** The customer
8. S3 bucket access configuration?
 - **ANSWER:** The customer

Activity: Scenario 2 of 2

Consider this deployment. Who is responsible – AWS or the customer?

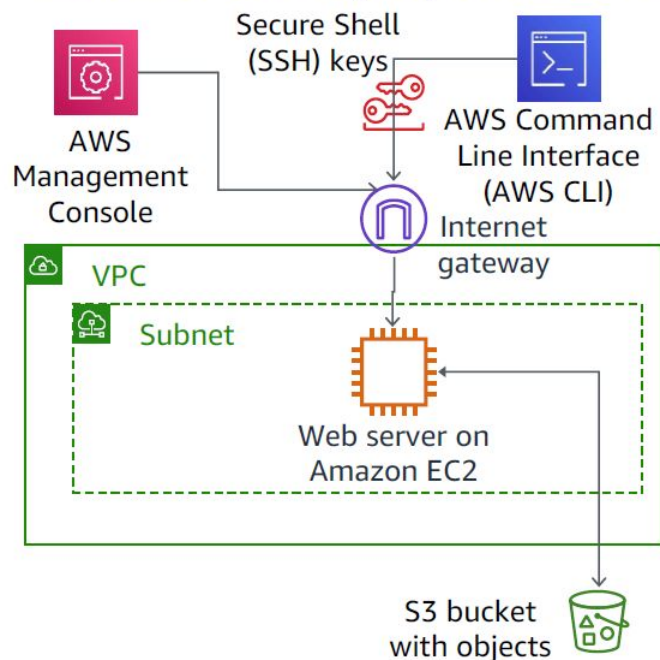


1. Ensuring that the AWS Management Console is not hacked?
2. Configuring the subnet?
3. Configuring the VPC?
4. Protecting against network outages in AWS Regions?
5. Securing the SSH keys
6. Ensuring network isolation between AWS customers' data?
7. Ensuring low-latency network connection between the web server and the S3 bucket?
8. Enforcing multi-factor authentication for all user logins?

Activity: Scenario 2 of 2 Answers

Consider

Consider this deployment. Who is responsible – AWS or the customer?



1. Ensuring that the AWS Management Console is not hacked?
 - **ANSWER:** AWS
2. Configuring the subnet?
 - **ANSWER:** The customer
3. Configuring the VPC?
 - **ANSWER:** The customer
4. Protecting against network outages in AWS Regions?
 - **ANSWER:** AWS
5. Securing the SSH keys
 - **ANSWER:** The customer
6. Ensuring network isolation between AWS customers' data?
 - **ANSWER:** AWS
7. Ensuring low-latency network connection between the web server and the S3 bucket?
 - **ANSWER:** AWS
8. Enforcing multi-factor authentication for all user logins?
 - **ANSWER:** The customer

- **WS Key Management Service (KMS)** is a managed service that allows you to create and control the encryption keys used to encrypt your data. It integrates with various AWS services to provide a secure way of managing encryption keys for securing sensitive data.

- **Example Use Case:**

- Suppose you are working at ShopEase, and you want to encrypt customer payment information before saving it to an S3 bucket. You could use AWS KMS to encrypt that data with a CMK and store the encrypted files, ensuring the data is safe.

AWS WAF (Web Application Firewall)

- **AWS WAF (Web Application Firewall)** is a security service that helps protect your web applications from common web exploits that could affect availability, compromise security, or consume excessive resources. AWS WAF allows you to control how traffic reaches your applications by filtering requests based on custom-defined rules.

Key Features:

- **Layer 7 Protection:** AWS WAF operates at the application layer, allowing you to filter HTTP and HTTPS requests based on various conditions such as IP addresses, HTTP headers, URIs, query strings, and body content.
- **Managed Rules:** AWS offers pre-configured rules to help protect against known vulnerabilities (e.g., SQL injection, Cross-Site Scripting).
- **Custom Rules:** You can create your own rules to allow or block specific traffic.
- **Rate Limiting:** AWS WAF provides rate-based rules to throttle traffic based on request rates, preventing denial of service (DoS) attacks.

Example Scenario:

- Let's say ShopEase, the e-commerce company you work for, is experiencing an increase in unwanted traffic from bots attempting SQL injection attacks. You can configure AWS WAF to protect your application by blocking such malicious requests.

AWS Shield

- **AWS Shield** is a managed Distributed Denial of Service (DDoS) protection service that safeguards web applications running on AWS from DDoS attacks. AWS Shield operates at the network and application layers, protecting against a variety of common attack types, including SYN/UDP floods, reflection attacks, and application-layer DDoS attacks.

- There are two tiers of AWS Shield:
- **AWS Shield Standard:** Automatically enabled for all AWS customers at no extra cost, providing protection against most common, large-scale DDoS attacks.
- **AWS Shield Advanced:** Provides more sophisticated protection, including 24/7 access to the AWS DDoS Response Team (DRT), detailed attack diagnostics, and financial protections (cost protection) during an attack

Key Features of AWS Shield:

- **Automatic Protection:** AWS Shield Standard is built into AWS services like CloudFront, Route 53, and Elastic Load Balancing, providing DDoS mitigation at no additional cost.
- **Advanced Threat Detection:** AWS Shield Advanced provides more sophisticated attack detection, real-time visibility, and mitigation techniques.
- **Global Threat Environment Dashboard:** A dashboard in Shield Advanced that shows detailed information about DDoS attacks and trends worldwide.
- **Cost Protection:** In the event of a DDoS attack, AWS Shield Advanced provides financial protection for scaling-related costs.

Example Scenario:

- Let's say **ShopEase**, your e-commerce company, experiences a spike in traffic during Black Friday sales. While some of this traffic is legitimate, there's concern about a DDoS attack that could potentially overwhelm the website. AWS Shield can be used to automatically mitigate such threats.